

CHAPTER 1: INTRODUCTION TO INFORMATION SYSTEMS SECURITY

Le Thi Bao Thu

Faculty of Computer Science & Engineering

HCMC University of Technology

thule@hcmut.edu.vn

Outline

1 Basic Concepts

2 Information System Components

3 Framework for DB & Applications Security

Basic Concepts

- ❑ Data and Information
- ❑ Information System
- ❑ Information Security
- ❑ Information System Security Requirements
- ❑ Countermeasures
- ❑ Basic Steps in Information Security Process

Data and Information

- ❑ **Data** are plain facts.
- ❑ When data are processed, organized, structured or presented in a given context so as to *make them useful*, they are called **Information**.
- ❑ ***Data -> Information -> Knowledge.***

Information Systems

- ❑ **Information System** refers to a system of people, data records and activities that process the data and information in an organization.



Information Systems Security

- ❑ **Information Security** means protecting information and information systems from *unauthorized access, use, disclosure, disruption, modification or destruction*.

Purposes of Information System Security



☐ **Prevention**

- *Prevent attackers from violating security policies*

☐ **Detection**

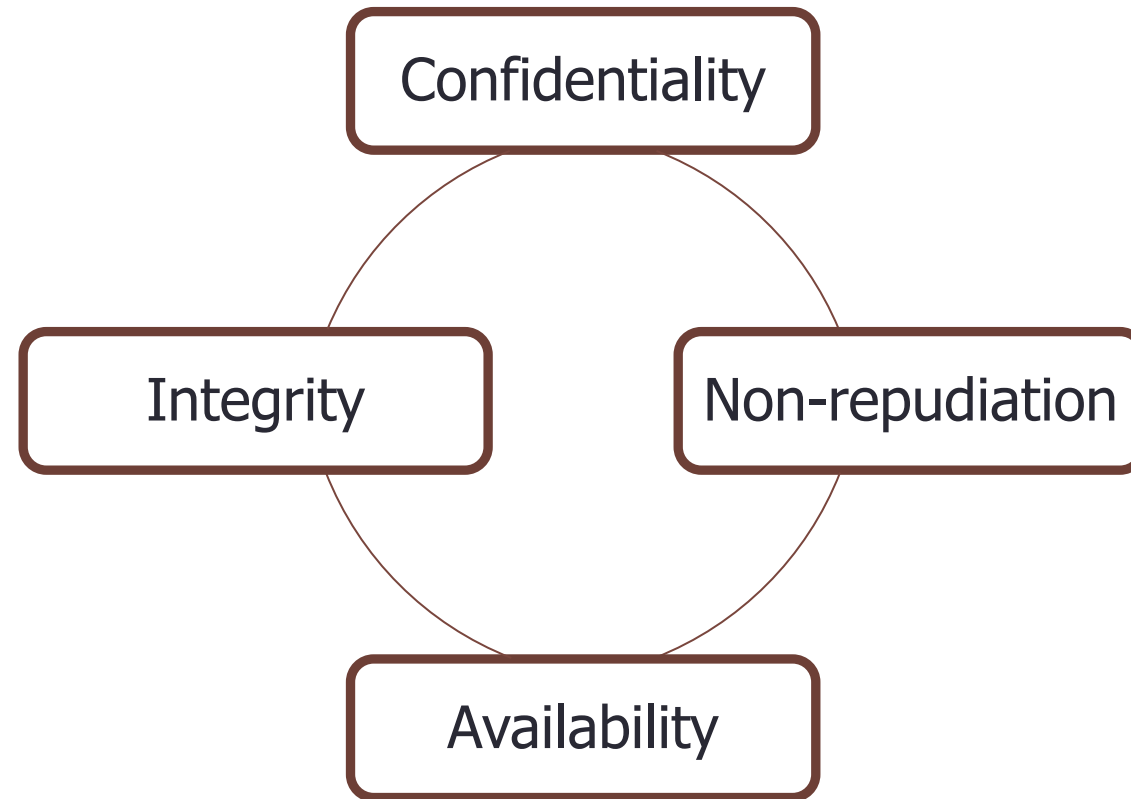
- *Detect attackers' violation of security policy*



☐ **Recovery**

- Stop attack, assess and repair damage
- Continue to function correctly even if attack succeeds

Information System Security Requirements



Information System Security Requirements

- ❑ **Confidentiality:** Protection of data from unauthorized disclosure
Example: In a bank system, preventing a client from finding out the information of another client, such as balance.
- ❑ **Integrity:** Only authorized users should be allowed to modify data.
Example: In a bank system, preventing a client from changing his or her balance.
- ❑ **Availability:** Making data available to the authorized users and application programs
Example: In a bank system, ensuring that the invoices are printed on time as required by law.
- ❑ **Non-repudiation:** The ability to prevent the effective denial of an act.
Example: In a bank system, providing proof of the origin and delivery of transactions from a client.

Countermeasures

- ❑ **Countermeasures** ensures these security requirements for information systems. There are some countermeasures:
 - Access control
 - Inference control
 - Flow control
 - Encryption

Basic Steps in Information Systems Security



- ❑ Identify threats
 - What could break your database system?
- ❑ Define a security policy
 - What the security system is expected to do?
- ❑ Choose security mechanism
 - How the security system should achieve the security goal?

Identify Threats



- ❑ Security threats: Events that bring violations to system are called threats.
- ❑ Grouped into categories:
 - Improper release of information → Confidentiality
 - Improper modification of data → Integrity
 - Denial of service → Availability
 - Denial of action → Non-repudiation

Some Common Threats

- ❑ Errors and Omissions
- ❑ Fraud and Theft
- ❑ Malicious Hackers
- ❑ Malicious Code
- ❑ Denial-of-Service Attacks
- ❑ Social Engineering

Errors and Omissions

- ❑ It is difficult to protect the system from the users who need to use it every day to destroy data **accidentally**.
- ❑ Errors and omissions attack the integrity of the system.
- ❑ The number-one threat to the system.
- ❑ Solutions:
 - Training
 - Security concept “least privilege”
 - Adequate and frequent backups of the information on the systems

Fraud and Theft

- ❑ The users are not accidentally destroying data but are **maliciously** destroying the information.
- ❑ The internal attacks is very dangerous.
- ❑ Solutions
 - Well-defined policies → gather evidence to find attackers (server log files...)

Malicious Hackers

- ❑ There are several groups of Internet users out there that will attack information systems.
- ❑ Three primary groups:
 - Hackers: who penetrates a system just to look around and see what is possible.
 - Crackers: who damage or destroy data if they are able to penetrate a system.
 - Phreaks: who breaks into an organization's phone system.
- ❑ The ways hackers attack: 5 steps
 - Reconnaissance : Collecting as much information as possible about the target network
 - Scanning: Looking for known vulnerabilities to compromise to gain access to the network.
 - Gaining access
 - Maintaining access: Uploading a backdoor application
 - Cover his track: Modifying log files

Malicious Code

- ❑ Malicious code (malware) is a set of instructions that cause security policies to be violated.
- ❑ Some common malicious code:
 - Virus
 - Worm
 - Trojan horse



Denial-of-Service Attacks

- ❑ A type of attack prevents anyone from accessing to the network.
- ❑ To overload the system about resources or network's telecommunication lines
- ❑ DoS: a system attacks a targets system, “one-to-one” attack
- ❑ DDoS (distributed denial of service): “many-to-one” attack

Social Engineering

- ❑ The goal of social engineering is to trick someone into providing valuable information or access to that information or resource.
- ❑ The social engineer exploits weakness of human nature:
 - The desire to be helpful
 - A tendency to trust people
 - The fear of getting into trouble
 - The willingness to cut corners
- ❑ Common types of Social Engineering:
 - Human-based social engineering
 - Computer-based social engineering

Human-based Social Engineering

- ❑ Dumpster Diving & Shoulder Surfing
- ❑ Impersonation
- ❑ Posing as Important User
- ❑ Third-person Authorization
- ❑ Technical Support

Computer-based Social Engineering

- ☐ Phishing
- ☐ Vishing
- ☐ Pop-up Windows
- ☐ Mail attachments
- ☐ Fake websites
- ☐ Interesting software

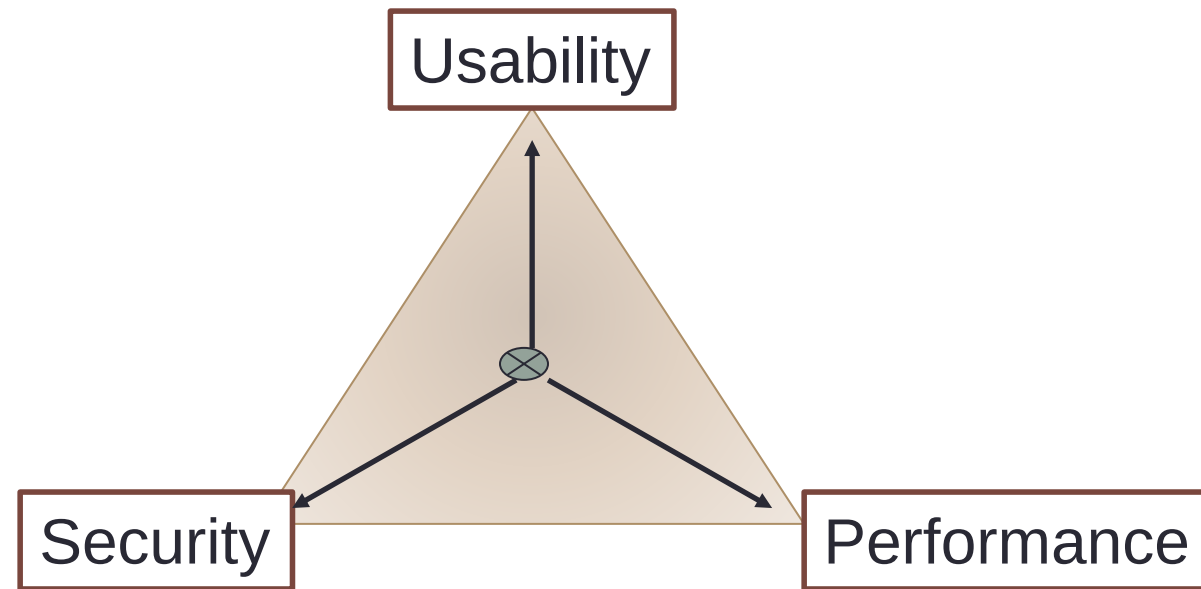
Define a Security Policy



- ❑ Policy says what is, and is not, allowed.
- ❑ Security begins with a clear and comprehensive security policy.
- ❑ Different policies for different needs. Composition of conflict policies may cause vulnerabilities.

Define a Security Policy

- ❑ A security policy should balance among three factors:



Choose Security Mechanism



- ❑ Mechanisms enforce policies.
- ❑ Security mechanisms may be:
 - Technical, in which controls in the computer enforce the policy; for example, the requirement that a user supply a password to authenticate herself before using the computer.
 - Procedural, in which controls outside the system enforce the policy; for example, firing someone for ringing in a disk containing a program obtained from an untrusted source.

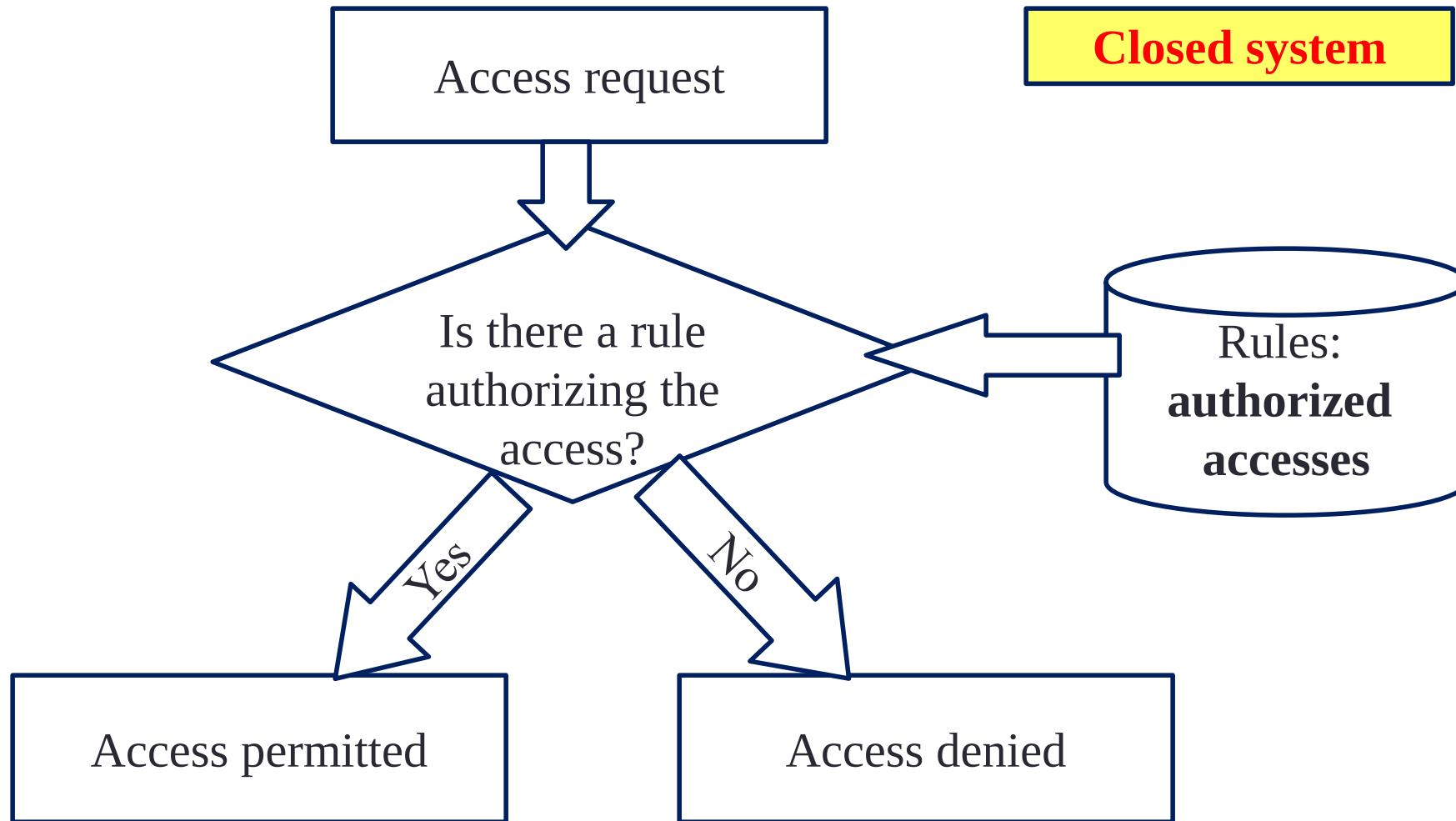
Database Security Mechanism

- ☐ Access control
- ☐ Inference control
- ☐ Flow control
- ☐ Encryption

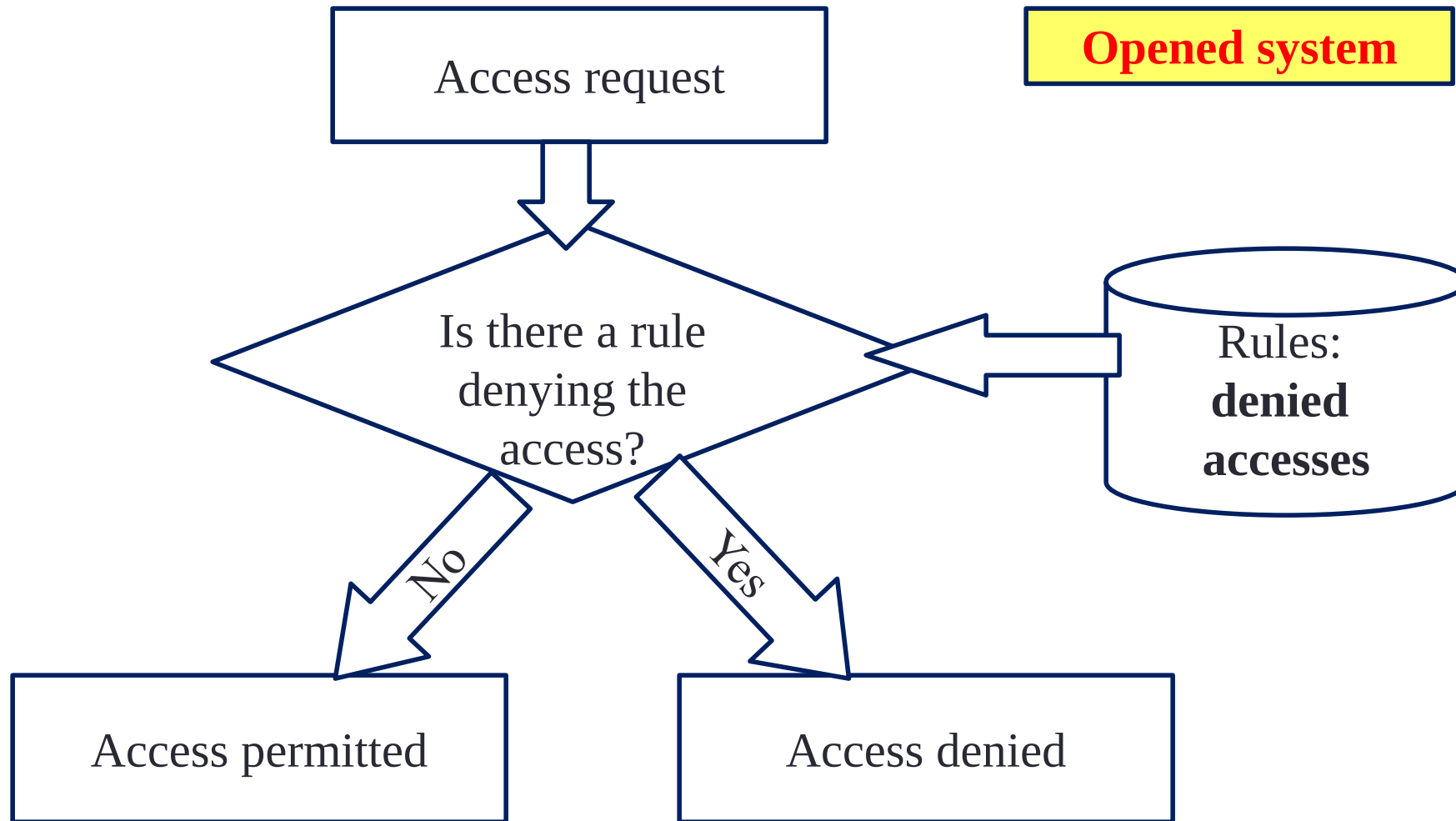
Access Control

- ❑ **Access Control:** The security mechanism for restricting access to the database as a whole
 - Handled by creating user accounts and passwords to control login process by the Database Management System (DBMS).
- ❑ Two types of access control system
 - Closed system
 - Open system

Access Control - Closed System



Access Control - Opened System



Access Control – Basic steps

- ❑ Basic Steps in Access control Process:

Identification

A user presents an identity to the database

Authentication:

The user proves that the identity is valid

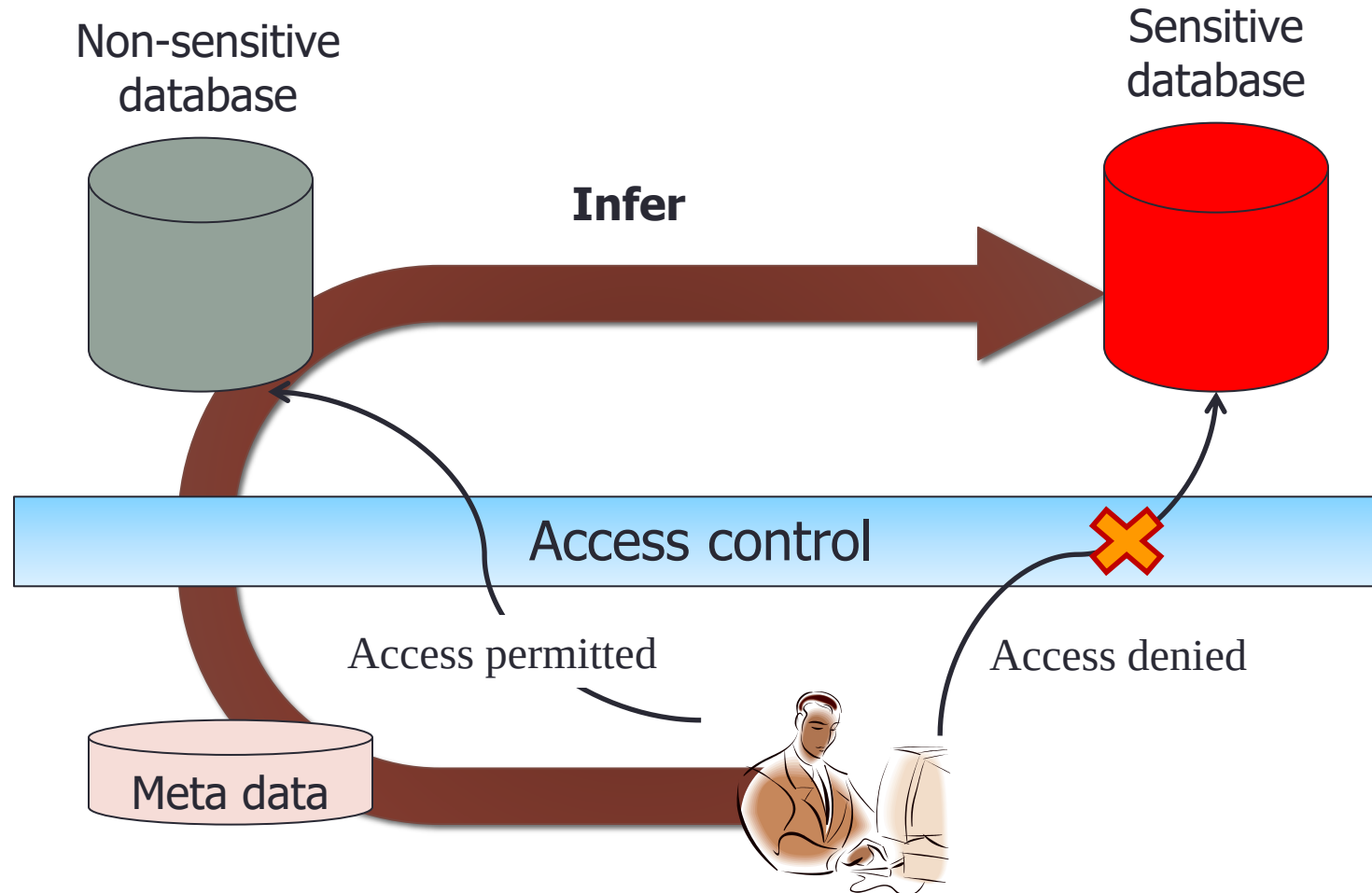
Authorization:

What privileges and authorizations the user has

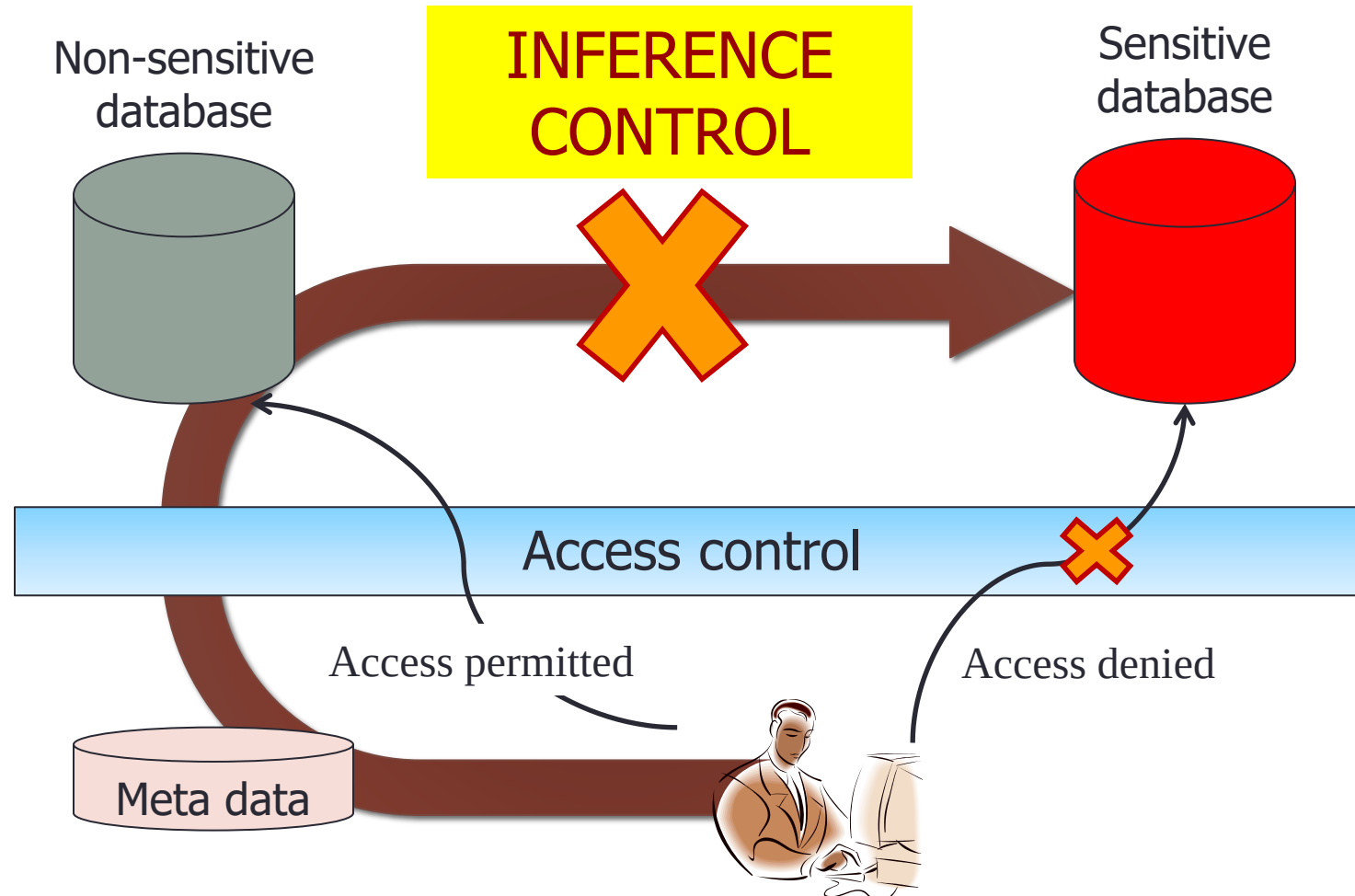
Inference control

- ❑ **Inference control:** The security problem associated with databases is that of controlling the access to a statistical database, which is used to provide statistical information or summaries of values based on various criteria.
- ❑ The countermeasures to statistical database security problem is called **inference control measures**.

Inference attack



Inference control



Flow control

- ❑ A **flow** between object X and object Y occurs when a program reads values from X and writes values into Y.
- ❑ **Flow control** prevents information from flowing from some objects into less protected objects so that it can reach unauthorized users.
- ❑ A **flow policy** specifies the channels which information is allowed to move.
 - Specifies just two classes of information: confidential (C) and non-confidential (N)
 - and allows all flows except those from class C to class N.
- ❑ Channels that are pathways for information to flow implicitly in ways that violate the security policy of an organization are called **Covert Channels**.
 - Storage channel
 - Timing channel

Convert chanel – Timing Chanel

❑ In Python:

```
def validate_password(actual_pw, typed_pw):  
    if len(actual_pw) <> len(typed_pw):  
        return 0  
    for i in len(actual_pw):  
        if actual_pw[i] <> typed_pw[i]:  
            return 0  
    return 1
```

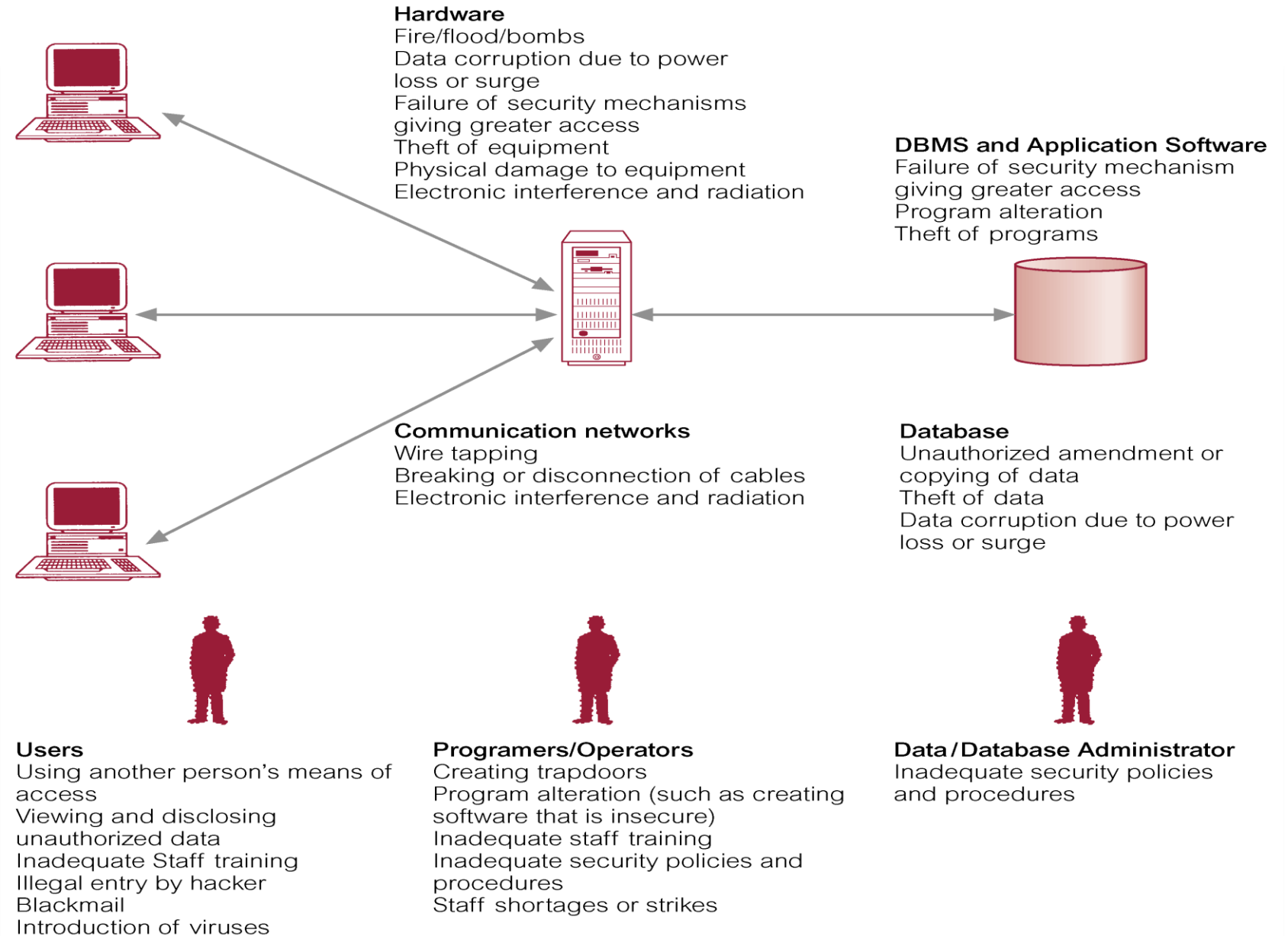
Encryption

- ❑ **Data encryption** refers to mathematical calculations and algorithmic schemes that transform **plaintext** into **cyphertext**, a form that is non-readable to unauthorized parties.
- ❑ Only the user having a correct key can decrypt the cyphertext, transforming it to the original plaintext version.
- ❑ Data encryption is used to protect sensitive data (such as credit card numbers).

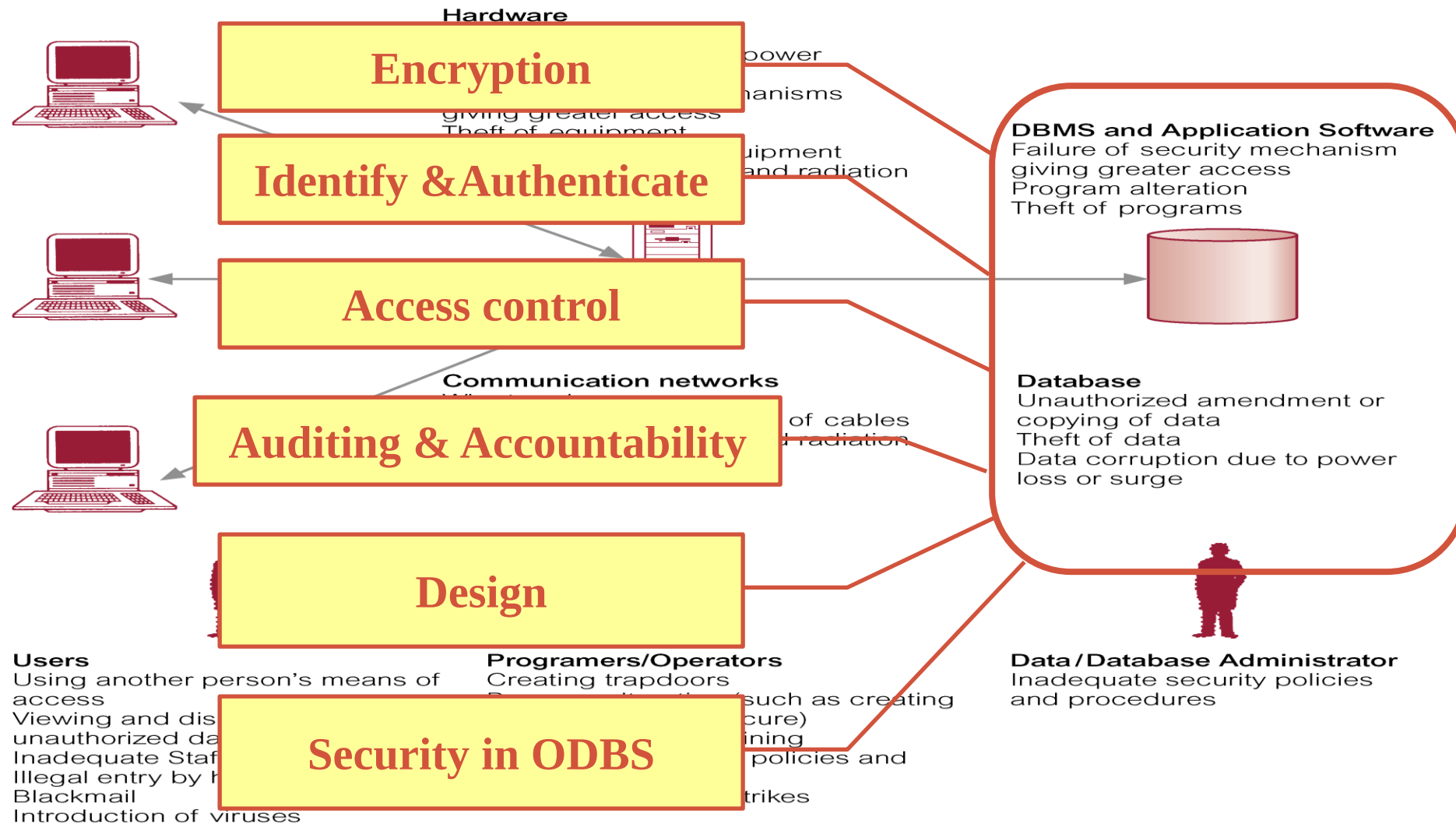
Outline

-
- 1 Basic Concepts
 - 2 Information System Components**
 - 3 Framework for DB & Applications Security
-

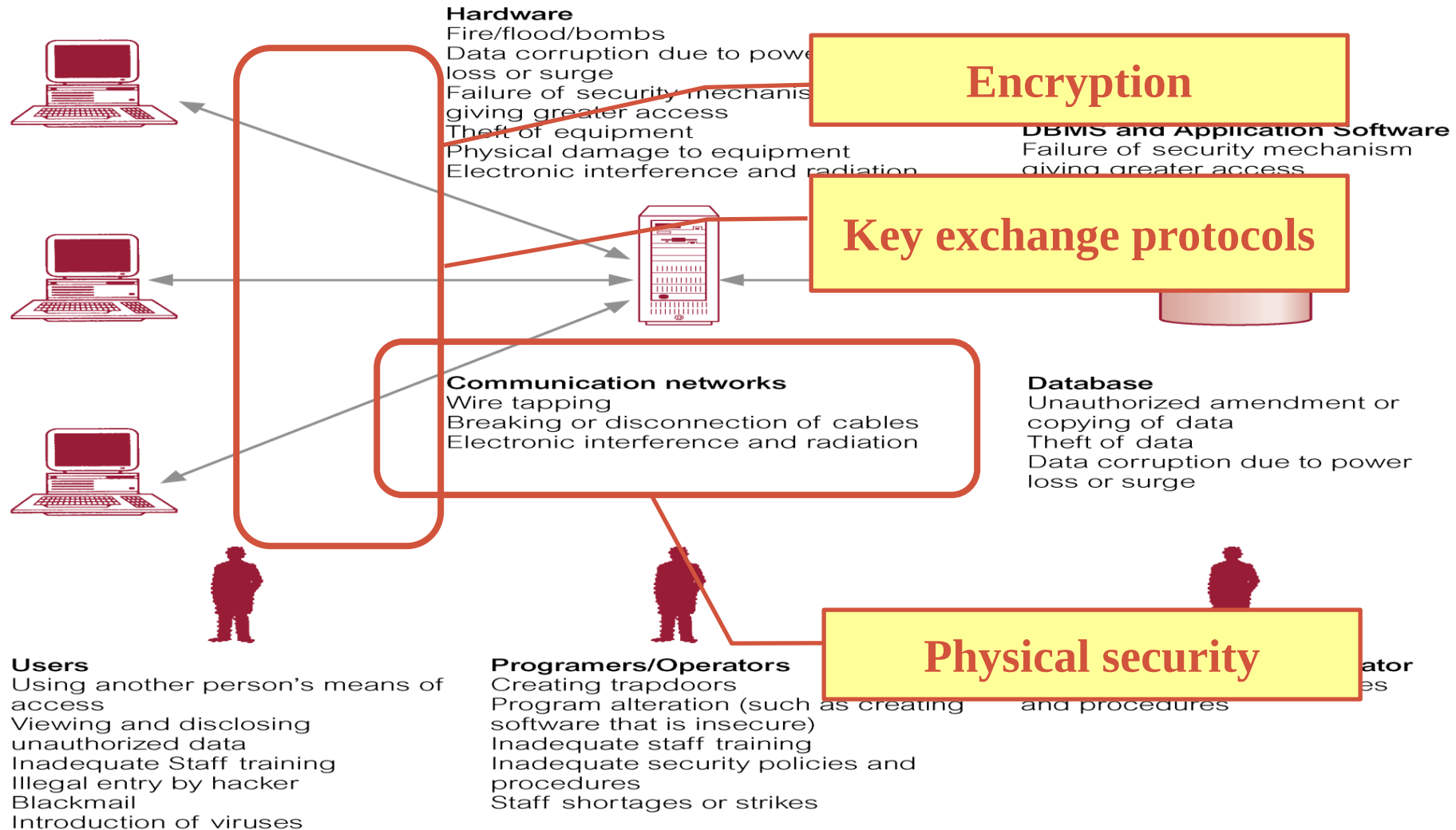
Information System Components



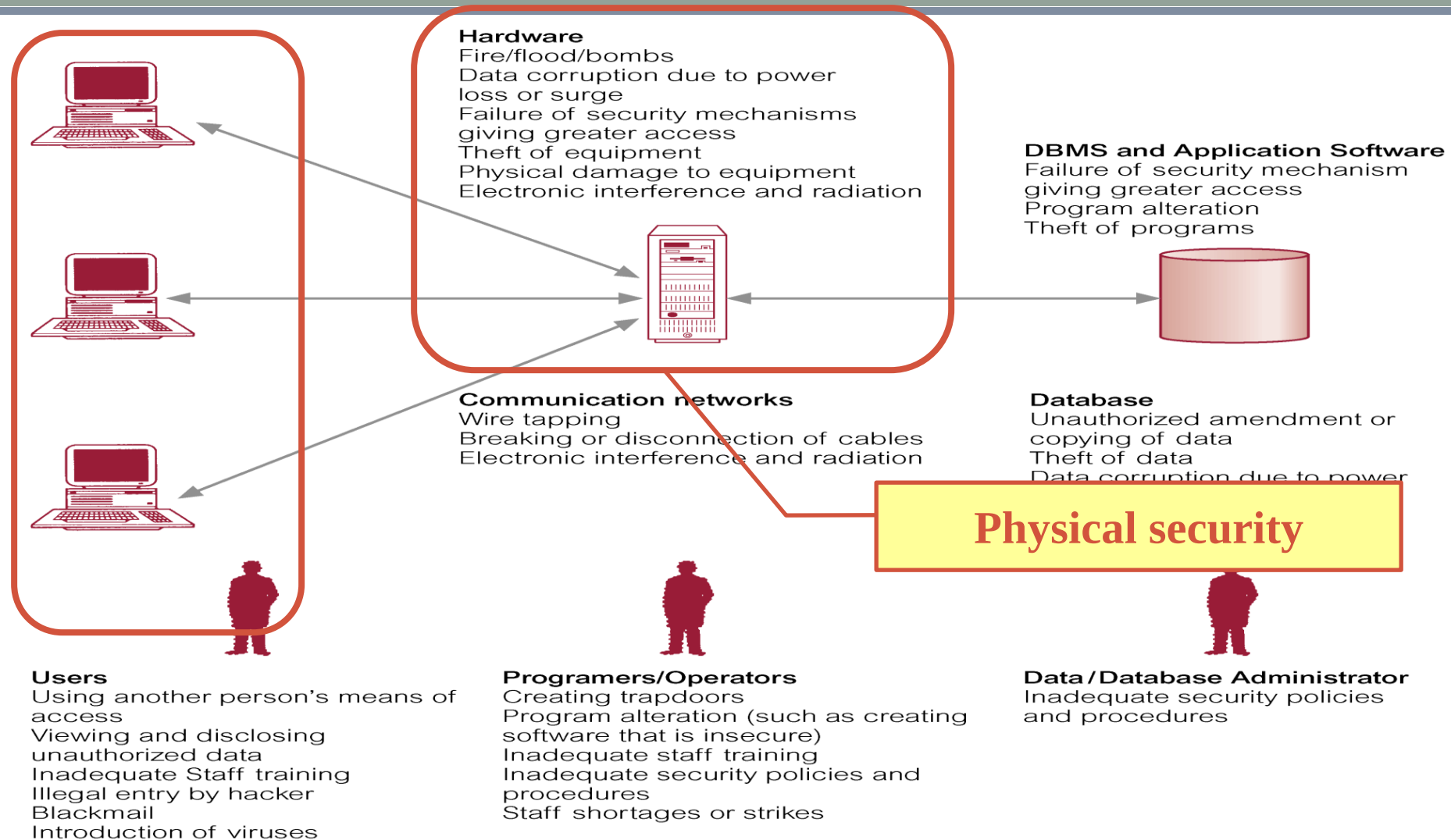
Information System Components



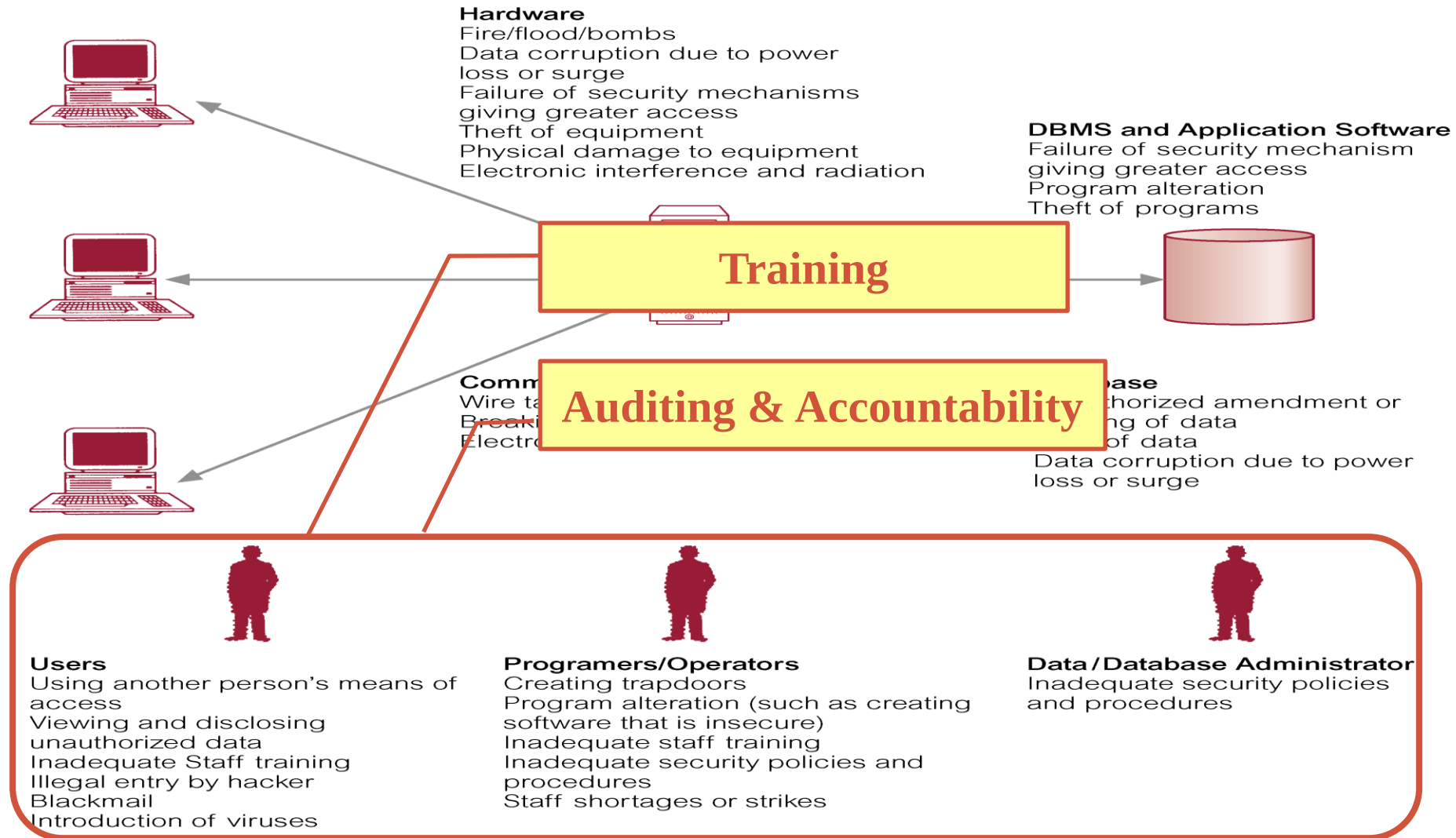
Information System Components



Information System Components



Information System Components



Outline

-
- 1 Basic Concepts
 - 2 Information System Components
 - 3 Framework for DB & Applications Security**
-

Framework for DB & Applications Security

Applications Security Technologies	Privacy, Dependable Information Management, Secure Information Management Technologies, Data Mining and Security, Digital Forensics, Secure Knowledge Management Technologies, Secure Semantic Web, Biometrics
Database Security Technologies	Relational DB Security, Distributed/Federated DB Security, Web DB Security, Object/Multimedia DB Security, Data Warehouse Security, Inference Problem, Sensor DB and Stream Data Processing Security
Supporting Technologies for DB & Applications Security	Database Systems, Information Retrieval, Knowledge Management, Information Management, Information & Computer Security

